정보보호컨설팅(Part Ⅰ)

목차

오리엔테이션

1. 정보보호컨설팅 개요
2. 컨설팅 프로세스 흐름
3. 컨설턴트 역량 & 윤리
4. 협업과 성과관리
5. 정보보호컨설팅 분류 및 유형
6. 기술적 보안진단

Q&A

목차

1. 정보보호컨설팅 개요
2. 컨설팅 프로세스 흐름
3. 컨설턴트 역량 & 윤리
4. 협업과 성과관리
5. 정보보호컨설팅 분류 및 유형
6. 기술적 보안진단

Q&A

1. 정보보호컨설팅 개요_정의

“정보보호컨설팅이란, 조직의 정보자산을 보호하기 위해 법·제도, 기술, 관리적 측면에서 위험을 진단·분석하고, 대응방안을 제시하여 보안 수준을 향상시키는 전문 서비스이다.”

컨설팅 정의(관련법률, 용어)

구분	근거	내용
정보보호 관련법령	정보보호 전문서비스 기업 지정 등에 관한 고시 제2조 (정보보호산업의 진흥에 관한 법률)	"정보보호 컨설팅"이란 정보통신시설 및 시스템을 안전하게 유지하기 위하여 보호대책 수립, 위험요인평가, 모의해킹, 마스터플랜 수립 등을 수행하는 일련의 과정을 말한다.
IT용어사전	정보통신용어사전 (한국정보통신기술협회(TTA))	“보안 컨설팅”이란 조직의 목적을 달성하는데 있어 전산시스템과 네트워크 등 모든 IT 자산과 조직에 일어날 수 있는 위험을 분석하고 이에 대한 대책을 수립함으로써 관리자와 조직이 그 대책을 실현할 수 있도록 지원하는 독립적인 전문 자문 서비스.

정보보호컨설팅 해석

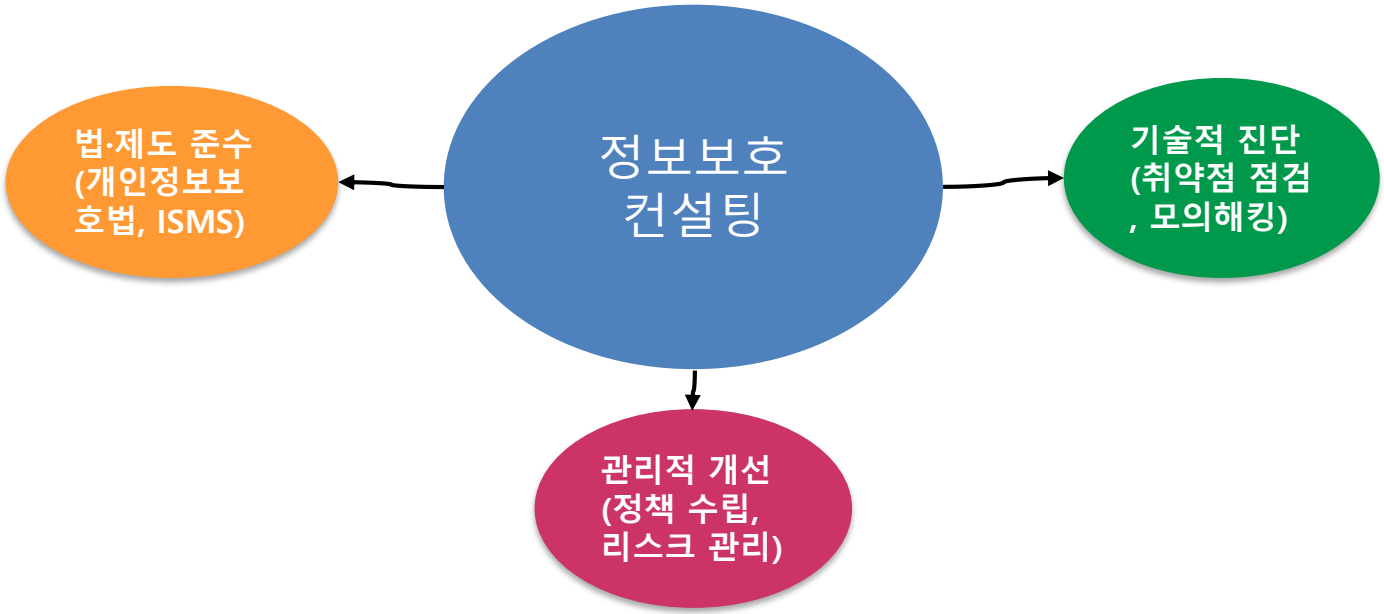
▪ 정보보호컨설팅은 조직의 정보 자산에 내재한 보안 위험을 식별하고, 이를 효과적으로 관리·통제할 수 있도록 기술적, 관리적, 물리적 보안 대책을 진단·설계·지원하는 전문 서비스입니다.

▪ 단순한 취약점 진단을 넘어, 법률 준수, 인증 획득, 보안체계 수립, 정책 정비, 사고 예방 및 대응 체계 마련까지 포함하는 전사적 보안 전략 수립 활동입니다.

즉, “현재 상태를 분석하고, 필요한 보안수준을 정의하며, 이를 실현 가능한 방안으로 구체화해주는 종합 진단 및 전략 수립 과정”

1. 정보보호컨설팅 개요_정의

정보보호컨설팅 정의



궁긍적 목적은

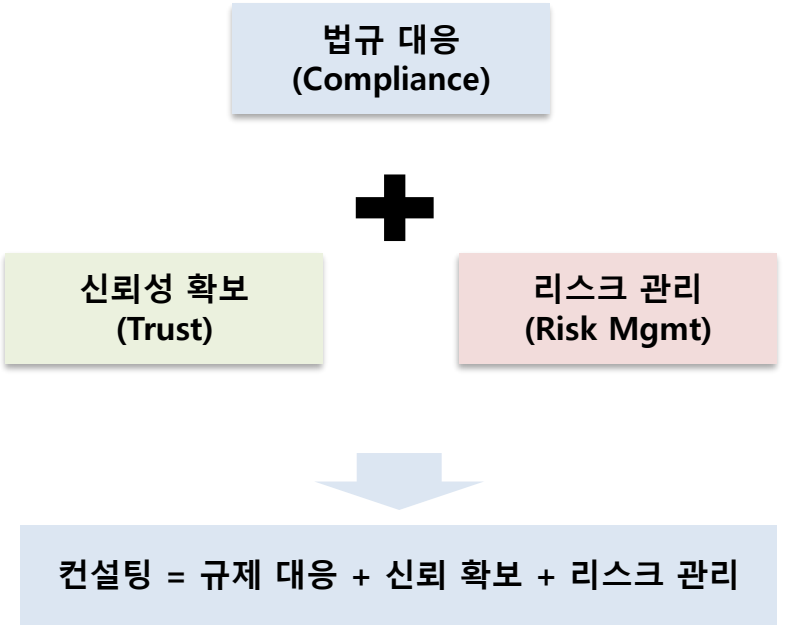
조직이 예방 중심 보안체계를 갖추도록 하고, 리스크 기반 접근(Risk-based approach)으로 지속적 개선을 가능하게 함

1. 정보보호컨설팅 개요_목적

“정보보호컨설팅은 단순 점검이 아닌, 법규 대응·신뢰성 확보·리스크 관리라는 3대 목적을 달성하여 조직의 보안 수준을 지속적으로 향상시키는 과정.”

정보보호컨설팅 목적

구분	주요 내용	기대 효과
법규 대응 (Compliance)	개인정보보호법, 전자금융거래법, 정보통신망법, ISMS/ISMS-P 등 법규 및 인증제도 충족	법규 위반 리스크 최소화, 인증 획득, 과징금/제재 예방
신뢰성 확보 (Trust)	안전한 서비스 제공, 고객·파트너·감독기관 대상 보안 수준 입증	기업 이미지 제고, 대외 신뢰 확보, 글로벌 경쟁력 강화
리스크 관리 (Risk Management)	기술·관리적 취약점 사전 식별, 위험 분석 및 개선	보안사고 예방, 재무 손실 및 업무 중단 방지, 지속적 개선 체계 수립



“조직 보안 수준 향상"

1. 정보보호컨설팅 개요_필요성

정보보호컨설팅은 기업이 사이버 위협과 법·규제를 안전하게 관리하도록 도와 사고를 예방하고 신뢰를 높이는 핵심 활동으로 전문가의 도움을 받아 보안 수준을 점검·개선하면 업무 연속성과 조직 경쟁력을 동시에 확보

정보보호컨설팅 필요성

구분	설명	포인트
사이버 위협 확대	- 해킹, 랜섬웨어, 피싱, 내부자 사고 등 공격 방식이 빠르게 다양해짐 - 한 번의 사고가 금전적 손실뿐 아니라 기업 이미지에도 큰 타격	위협 환경 변화
법적·규제 준수	- ISMS·ISMS-P 인증, 개인정보보호법, 전자금융감독규정 등 보안 관련 법·규제가 강화됨 - 미 준수 시 과태료·사업 정지·인증 취소 등 직접 피해 발생	규제 요구 충족
경영 안정성 & 신뢰	- 정보자산을 안전하게 관리하면 서비스 중단·데이터 유출을 예방 - 고객과 파트너에게 "안전한 조직"이라는 신뢰를 줄 수 있음	안정성 & 신뢰
전문가의 체계적 지원	- 내부 인력만으로는 최신 공격기술과 대응방안 파악이 어려움 - 컨설턴트는 위험을 분석하고, 필요한 정책·기술을 단계별로 제안	전문성 확보
비용 대비 효과	- 사고 후 복구 비용은 예방 비용보다 훨씬 크며, 평판 손실은 금액으로 환산 불가 - 컨설팅은 사고를 미리 막아 장기적으로 비용 절감 효과	가성비 (Cost-effectiveness)

정보보호컨설팅은 단순 점검이 아니라, 조직의 현재 위치를 정확히 파악하고 앞으로의 위험을 미리 줄이는 전략 도구

1. 정보보호컨설팅 개요_국내/글로벌 보안시장 트렌드

사이버 위협의 다양화·지능화로 보안 투자가 계속 증가하고 있으며, 클라우드, AI, OT/IoT 환경 확산 → 보안 패러다임 변화되고 있음. 글로벌 시장은 제로트러스트·AI보안·규제 준수 중심으로 성장하고 있으며, 국내 시장은 ISMS-P/마이데이터/클라우드 보안 수요가 강세



국내/글로벌 보안시장 트렌드

구분	2025년 주요 트렌드	시사점
글로벌	- 제로트러스트 아키텍처 확산 - AI/ML 기반 위협 탐지 강화 - SaaS 보안 관리(SSPM) 부상 - 공급망 보안(Third Party Risk) 강조	▸ 글로벌 레퍼런스 & 표준 이해 필요 ▸ 신기술(SSPM, AI보안) 컨설팅 역량 확보
국내	- ISMS·ISMS-P 인증 수요 지속 확대 - 클라우드 전환 프로젝트 급증 - 개인정보 규제 강화 & 마이데이터 산업 확대 - OT/스마트팩토리 보안 관심 증가	▸ 인증·컴플라이언스 컨설팅 기회 확대 ▸ 클라우드·OT 보안 아키텍처 제안 스킬 필수
시장 규모	- 글로벌 정보보안 시장 2025년 약 **$2000억** 전망 - 국내 보안 시장 연평균 성장률 **7~8%**	▸ 산업별 성장영역을 파악 → 제안·영업에 활용
위협 트렌드	- 랜섬웨어, 공급망 공격, 클라우드 설정오류 - AI 악용(딥페이크, 자동화 공격)	▸ 최신 공격사례 분석 → 대응방안 컨설팅

컨설턴트 Insight → "기술+규제 모두 이해한 보안전략 제안이 핵심"

1. 정보보호컨설팅 개요_산업별 컨설팅 수요 – 금융, 제조, 공공 사례

산업별 보안 요구사항과 규제가 달라 컨설팅 포인트도 다르게 접근해야 하며, 금융은 규제·감독 중심, 제조는 OT/스마트팩토리 보안, 공공은 국가·개인정보 보호에 집중, 도메인별 위험 시나리오를 이해하고 맞춤형 개선안 제시

산업별 컨설팅 수요

산업	컨설팅 수요 영역	주요 사례	컨설턴트 포인트
금융	- 전자금융거래법, 전자금융감독규정 대응 - 데이터 보안(암호화·DLP), 계정권한관리 - 전자금융 인프라 취약점 점검	• 대형은행 ISMS-P 컨설팅 • 카드사 클라우드 전환 보안성 검토	▸ 법규 및 금융감독원 지침 이해 ▸ 보안성과 **비즈니스 연속성** 균형 제안
제조	- 스마트팩토리/OT 보안체계 구축 - 산업제어시스템(ICS) 취약점 진단 - 해외 공급망 보안 요구	• 글로벌 자동차사 생산라인 OT 진단 • 반도체사 공급망 관리 컨설팅	▸ IT·OT 융합 위협 분석 ▸ 규제+표준(IEC62443) 기반 개선 로드맵
공공	- 개인정보 보호 및 국가 정보보호 지침 - 공공 클라우드 전환 보안성 평가 - 전자정부 서비스 취약점 분석	• 지자체 클라우드 보안성 심사 • 중앙부처 개인정보 관리체계 컨설팅	▸ 법령·가이드(KISA, NIS) 준수 ▸ 행정 효율성과 보안의 조화

"산업별 특화 지식 + 보안 프레임워크 적용 능력이 컨설턴트의 경쟁력"

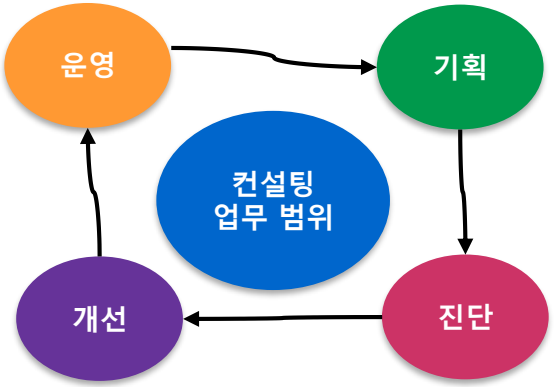
1. 정보보호컨설팅 개요_컨설팅 업무 범위

보안컨설팅은 '기획 → 진단 → 개선 → 운영'의 4단계 업무로 구성

컨설팅 업무 범위

- **기획: 고객의 요구와 목표를 정의하고 컨설팅 로드맵을 수립**
- **진단: 관리·기술·물리 영역의 현황을 분석, 위험과 취약점을 식별**
- **개선: 우선순위에 따라 실행 가능한 보안대책을 설계 및 제안**
- **운영: 개선안 이행 여부를 점검하고, 성과를 관리·지속 지원**

단계	주요 내용	산출물 예시	컨설턴트 역할
① 기획	• 요구사항 수집·분석 • 컨설팅 범위·일정·목표 수립 • 계약 및 제안서 확정	제안서, 과업계획서, 일정표(WBS)	고객의 환경·목표를 이해하고 현실적 로드맵을 설계
② 진단	• 관리적 정책·절차·조직 점검 • 기술 영역(서버·네트워크·웹 등) 취약점 분석 • 인터뷰·문서 리뷰 수행	진단 체크리스트, 인터뷰 기록, 현황분석 보고서	리스크 식별과 우선순위 도출
③ 개선	• 위험 완화 대책 설계 • 정책·기술·프로세스 개선안 제시 • 실행계획(Roadmap) 수립	개선 보고서, 보안 아키텍처 설계안, 개선 일정표	실행 가능한 솔루션 제안 및 협의
④ 운영	• 개선 이행 점검 및 효과 검증 • 유지관리 가이드 제공 • Follow-up 컨설팅	운영 점검표, 사후 보고서, KPI 대시보드	지속 가능한 보안 체계 정착 지원



1. 정보보호컨설팅 개요_보안컨설팅의 가치

보안컨설팅은 조직이 위험을 줄이고, 비용을 절감하며, 신뢰성을 확보하도록 돕는 전략적 투자이며, 동시에 컨설턴트에게는 전문성 강화와 커리어 성장을 보장하는 매력적인 직업 분야

보안컨설팅의 가치

구분	설명	포인트
위험 최소화	- 해킹, 랜섬웨어, 내부자 사고 등 보안사고를 사전에 예방 - 사고 발생 시 피해 범위를 줄이고 복구 속도를 높임	"사고를 막거나 피해를 최소화"
비용 절감	- 예방 컨설팅 비용은 사고 복구·평판 손실 비용보다 훨씬 낮음 - 효율적인 보안 투자로 중복 비용을 방지	"예방은 최고의 절약"
신뢰성 확보	- 안정적인 서비스 운영으로 고객·파트너의 신뢰 확보 - 규제 준수로 기업 이미지와 브랜드 가치 상승	"신뢰는 기업의 경쟁력"
조직 경쟁력 강화	- 보안 수준이 향상되면 서비스 품질·경영 안정성도 동반 상승 - 글로벌 시장 진출 시 보안 인증은 필수 경쟁 요소	"보안은 비즈니스 성장의 기반"
커리어 성장 매력	- 컨설턴트는 다양한 산업·환경을 경험하며 전문성 축적 - 고급 분석·설계 역량은 시장에서 높은 가치 인정 - 리스크 관리, 거버넌스, 최신 기술 등 다방면 성장 가능	"전문가로서 성장과 안정 모두 확보"

보안컨설팅은 조직의 리스크를 낮추고 신뢰를 높이는 동시에, 개인에게는 지속적인 배움과 커리어 확장의 기회를 제공합니다. 즉, "조직과 컨설턴트 모두에게 이익이 되는 상생의 영역"

1. 정보보호컨설팅 개요_컨설팅의 특징

컨설팅은 기간이 정해진 프로젝트이면서도, 고객과 함께 만들어가는 공동 작업의 성격을 가지며, 성공적인 컨설팅은 범위·일정·품질 관리와 고객과의 협업 구조가 핵심임

컨설팅의 특징

구분	프로젝트 성격	고객 협업
목표	문제 해결과 개선안 도출이 최종 목적	고객과 목표를 명확히 합의
범위	제안 시점의 목표 + 진행 중 점진적 구체화	변경 발생 시 고객과 즉시 협의
일정	제한된 기간 내 산출물 제출	마일스톤·중간보고를 통한 진행 공유
품질	객관적 증적과 표준 기반 산출물 필요	고객 검토·피드백 반영 과정 필수
협업 문화	신뢰·투명성·소통 기반	정기 회의, 공동 워크숍, 문서 공유체계

컨설팅은 단순히 보고서를 작성하는 게 아니라, 고객과 함께 문제를 해결해 나가는 프로젝트 성격을 가짐

목차

1. 정보보호컨설팅 개요
2. 컨설팅 프로세스 흐름
3. 컨설턴트 역량 & 윤리
4. 협업과 성과관리
5. 정보보호컨설팅 분류 및 유형
6. 기술적 보안진단

Q&A

2. 컨설팅 프로세스 흐름_프로세스 전체 맵

정보보호컨설팅은 관리, 기술, 법·규제, 클라우드·신기술 등 다양한 영역에서 조직의 보안 수준을 진단하고 개선, 각 서비스는 위험을 줄이고, 법적 요구를 충족하며, 안정적인 IT 환경을 운영할 수 있도록 지원

프로세스 전체 맵

단계	주요 활동	산출물 예시	컨설턴트 역할
① 제안	고객 요구 분석, 제안서 작성, 견적 산출	제안서, 범위 정의서	고객 요구에 맞춘 서비스 설계
② 착수	Kick-off 미팅, 일정·역할 확정	과업계획서, WBS	프로젝트 방향·협업 구조 확립
③ 진단	관리·기술 점검, 인터뷰·문서 검토	진단 체크리스트, 현황 분석 보고서	보안수준 객관적 평가
④ 보고	분석결과 공유, 개선 우선순위 제시	진단 결과 보고서	문제점·리스크 가시화
⑤ 개선	정책/기술 개선안 설계, 실행 로드맵	개선 보고서, 실행계획	실행 가능한 보안대책 제안
⑥ 운영	개선 이행 점검, 사후 지원, 성과관리	운영 보고서, KPI 대시보드	지속 가능한 체계 정착 지원



2. 컨설팅 프로세스 흐름_제안 단계

RFP(Request For Proposal): 고객이 요구사항을 문서화해 배포하는 것이며, 제안서(Proposal): 컨설팅사가 고객의 요구에 맞춰 작성하는 대응 문서이다. 제안 단계의 성패는 고객 요구 이해 + 차별화된 솔루션 제시에 달려 있음

제안 단계



고객 요구사항 문서

- 프로젝트 배경 및 목적
- 요구사항(관리·기술 규제)
- 예산, 일정, 산출물 조건
- 평가 기준(기술/가격/실적 등)

√ 고객 Pain Point 명확화
√ 차별화된 방법론 강조

컨설팅 대응 문서

- 고객 요구 분석 & 문제 정의
- 컨설팅 방법론·접근법 제시
- 차별화 전략(실적, 전문성)
- 일정·인력·산출물 제시

√ 현실적인 일정·인력 구성
√ 산출물 품질 보장

2. 컨설팅 프로세스 흐름_제안 단계(예산·일정 협상)

컨설팅 프로젝트는 예산·일정 협상이 핵심이며, 고객은 비용 최소화 + 일정 단축을 선호, 컨설턴트는 품질 확보 + 현실적 자원 배분을 강조 따라서, Win-Win 협상을 통해 합리적 계약 체결이 중요

예산·일정 협상

구분	주요 내용	컨설턴트 포인트
예산 산정	- 투입 인력 수, 기간, 산출물 범위에 따라 책정 - 부대비용(여비, 도구 라이선스) 고려	▸ 세부 내역을 투명하게 제시 ▸ '투자 대비 효과(ROI)' 강조
일정 협의	- 고객: 빠른 결과 선호 - 컨설턴트: 최소한의 진단/검증 시간 필요	▸ 단계별 마일스톤 설정 ▸ 리스크 반영한 여유 기간 포함
계약 조건	- 범위, 책임, 지불조건 명시 - 범위 변경 시 추가비용 규정 필요	▸ 계약서에 **변경관리 조항** 포함 ▸ 지불 구조(착수금·중도금·잔금) 명확화
협상 방식	- 고객의 Pain Point와 우선순위를 파악 후 대응 - 단순 가격이 아닌 "가치 중심 협상"	▸ 대체안(Option) 제시 ▸ 경쟁사 대비 차별성 강조

협상 성공 포인트

- **투명성: 비용·일정 근거를 수치/표로 제시**
- **유연성: 옵션(예: 기본안 vs 확장안) 제공**
- **신뢰성: 프로젝트 품질·성과 보장 강조**
- **문서화: 합의사항은 반드시 계약서/부속합의서에 반영**



2. 컨설팅 프로세스 흐름_착수 단계(Kick-off 미팅)

Kick-off 미팅은 프로젝트 시작을 공식화하고 목표·범위·역할을 명확히 합의하는 자리이며, 모든 이해관계자가 같은 그림을 공유해야 프로젝트 리스크를 줄일 수 있음

Kick-off Meeting Agenda

구분	주요 내용	세부 내용
목적	프로젝트 공식 시작 선언	이해관계자 간 공통된 목표와 방향성 공유, 협업 체계 확립
프로젝트 개요	범위 및 기대효과 확인	컨설팅 목적, 진단·분석 범위, 기대되는 개선효과 설명
일정 및 산출물	단계별 계획 공유	전체 일정, 주요 마일스톤, 제출 산출물(PPT/보고서/체크리스트 등) 안내
역할과 책임 (R&R)	참여자별 역할 명확화	컨설팅팀(수행/보고), 고객 담당자(자료 제공/검토), 협력사(지원)
커뮤니케이션	의사소통 방식 확립	정기 회의 주기, 보고 체계(주간보고, 중간보고, 최종보고), 연락 담당자
리스크 및 유의사항	잠재 이슈 관리	일정 지연, 자료 미비, 이해관계 충돌 등 예상 리스크와 대응 계획
기대효과	신뢰와 협력 기반 구축	프로젝트 추진의 불확실성 최소화, 고객-컨설팅사 간 원활한 협업 보장

2. 컨설팅 프로세스 흐름_진단 단계(관리적 진단)

관리적 진단은 ISMS, ISMS-P 등 관리체계 기준에 따라 정책·조직·절차·교육·운영 기록을 점검하는 과정임(목표: "조직이 보안 규정을 제대로 만들고 운영하는지 확인")

관리적 진단 범위

구분	점검 항목	주요 확인 포인트
정책·지침	보안정책, 지침, 매뉴얼	최신화 여부, 경영진 승인 기록
조직·인력	보안담당자, 책임자 지정	CISO 권한, 역할·책임 정의
위험관리	위험 분석 및 대응 절차	자산 식별, 위협·취약점 관리
교육·훈련	임직원 보안 교육, 침해 대응 훈련	연간 계획 수립, 참여율 기록
사고 대응	보안사고 보고·처리 프로세스	사고 대응 매뉴얼, 로그 관리
운영 기록	정기 점검 및 회의 기록	내부 점검 보고서, 회의록



관리적 진단 특징

- **문서 기반 점검 → 정책·절차·기록 확인**
- **인터뷰 병행 → 담당자 인터뷰로 운영 실태 확인**
- **증적 확보 중요 → 정책 문서 + 실행 증적(로그, 보고서) 함께 확인**

2. 컨설팅 프로세스 흐름_진단 단계(기술적 진단)

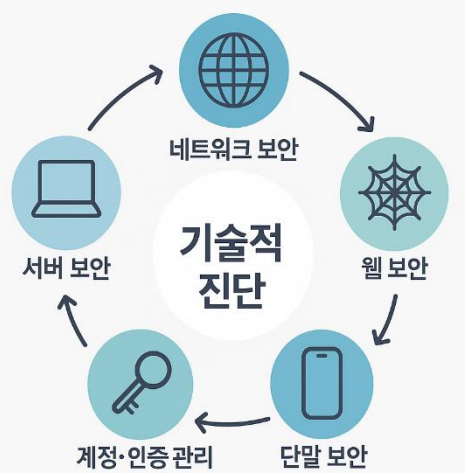
기술적 진단은 시스템·네트워크·애플리케이션에 대한 취약점을 식별하는 과정이며, 보안사고 예방을 위해 공격자 관점에서 점검하는 것이 특징임(목표: “침투 가능성 차단 + 보안 수준 객관화”)

기술적 진단 범위

구분	점검 항목	주요 확인 포인트
서버 보안	OS·DB·미들웨어 취약점	패치 적용 여부, 계정·권한 관리, 불필요 서비스 제거
네트워크 보안	방화벽, IPS/IDS, 라우터·스위치	ACL 규칙 검증, 포트·프로토콜 관리, 로그 모니터링
웹·애플리케이션 보안	OWASP Top 10 기반 취약점 점검	SQL Injection, XSS, 인증·세션 관리, 업로드 취약점
클라이언트 단말	PC·모바일 기기 보안	최신 보안패치, 악성코드 탐지, 보안설정 준수
계정·인증 관리	사용자 계정·권한·비밀번호	최소 권한 원칙, 비밀번호 정책, 다중 인증 적용 여부

기술적 진단 특징

- **자동화 도구 활용: 취약점 스캐너, 포트 스캐너 등**
- **수동 점검: 전문가 검증, 모의해킹(침투 테스트)**
- **재현성 확보: 진단 결과를 스크린샷·로그 형태로 증적화**

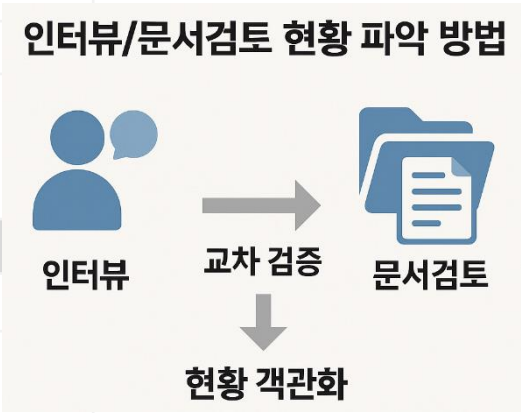


2. 컨설팅 프로세스 흐름_진단 단계(인터뷰/문서검토 현황 파악 방법)

인터뷰는 담당자와의 대화를 통해 운영 현황·이슈 확인하며, 문서검토는 정책, 절차, 보고서 등 공식 자료를 확인하여 증적 확보하는 것임(목적: "말과 기록을 함께 확인해 실제 운영 상태를 객관적으로 파악")

인터뷰 방법

구분	주요 포인트	체크리스트
대상자 선정	CISO, 보안담당자, IT운영팀, 개발팀 등	역할별 인터뷰 대상 목록 작성
질문 준비	개방형 질문("어떻게 운영되나요?") / 폐쇄형 질문("월 1회 점검합니까?") 병행	질문지(Interview Sheet) 사전 배포
진행 방식	기록 담당자 지정, 구두 답변은 증적 문서로 교차 확인	인터뷰 회의록 작성, 참석자 확인 서명
성과물	인터뷰 기록지, 운영 현황 요약	증적과 비교하여 일관성 확인



문서검토 방법

구분	주요 포인트	체크리스트
정책·절차	보안 정책, 지침, 매뉴얼 최신화 여부	최종 승인일자 확인
운영기록	교육·훈련 기록, 사고 대응 보고서, 점검 보고서	실제 실행 여부 증적 확보
기술 설정문서	서버/네트워크 구성도, 접근권한 관리대장	시스템 환경과 일치 여부
성과물	문서 검토결과표, Gap 분석 자료	미흡/부적합 항목 명시

2. 컨설팅 프로세스 흐름_보고 단계(보고서 작성)

보고서는 진단 결과 + 개선 권고사항을 고객에게 명확히 전달하는 공식 산출물(목적: 고객이 보안 수준을 이해하고, 개선 실행을 위한 가이드로 활용하도록 하는 것)

인터뷰 방법

구분	주요 내용	작성 포인트
표지 & 개요	프로젝트명, 기간, 참여자, 목적	고객 조직명, 보안 목적을 명확히 기재
프로젝트 개요	범위, 방법론, 일정, 수행 절차	그림/다이어그램 활용
진단 결과 요약	관리적/기술적 진단 주요 Findings	심각도(High/Medium/Low) 분류
세부 진단 결과	항목별 점검 결과 + 증적	스크린샷, 로그, 문서 캡처 포함
위험도 분석	자산·위협·취약점·위험 평가	리스크 매트릭스 시각화
개선 권고안	단기·중기·장기 개선 방안	실행 우선순위, 담당부서 제시
부록	점검 체크리스트, 인터뷰 기록	투명성·재현성 확보



작성 원칙

- **가독성: 그래프·표 활용, 불필요한 기술 용어 최소화**
- **객관성: 증적 기반(로그, 스크린샷), 단순 주장 금지**
- **실용성: 개선안은 실행 가능한 수준으로 제시**
- **맞춤화: 고객 조직 특성(산업, 규모, 환경)에 적합하게 작성**

2. 컨설팅 프로세스 흐름_개선 단계

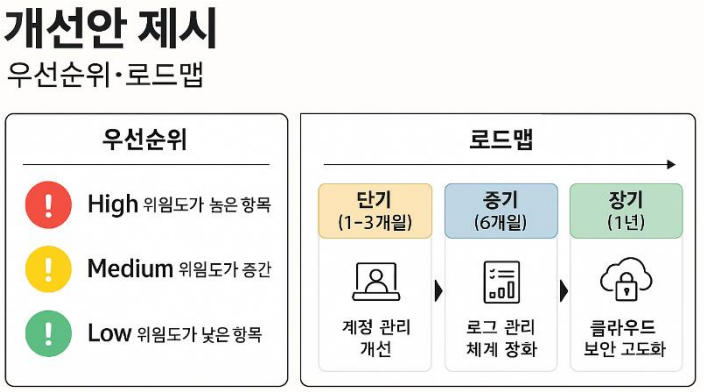
개선안은 위험도, 영향도, 실행 난이도를 고려해 우선순위화하며, 단기·중기·장기형태로 로드맵(Timeframe)으로 나눠 실행 계획을 제시, 고객이 실행 가능한 현실적 방안으로 느낄 수 있도록 구체화 필요

개선안 우선순위 기준

구분	기준	예시
High Priority	위험도 High + 즉시 개선 가능	계정 공용 사용, 방화벽 Any Any 허용
Medium Priority	위험도 Medium + 중기적 대응 가능	로그관리 미흡, 백업 절차 불충분
Low Priority	위험도 Low + 장기 개선 필요	클라우드 거버넌스 고도화

개선안 로드맵

기간	주요 개선 과제	실행 포인트
단기 (1~3개월)	- 관리자 계정 분리 - 패치 관리 프로세스 적용	빠른 효과, 즉시 대응 가능
중기 (6개월)	- 보안 로그 통합 관리 - 네트워크 세분화 적용	인프라 변경 수반
장기 (1년)	- 클라우드 보안체계 고도화 - 침해대응 자동화	투자·조직 변화 필요



2. 컨설팅 프로세스 흐름_운영 단계

보안컨설팅은 일회성 진단이 아니라 지속적 관리 프로세스, 개선 실행 여부 점검, 교육 지원, 재진단 등을 통해 실질적 보안 수준 향상을 보장

운영 지원 주요 방식

단계	주요 활동	목적
성과 점검	- 개선 권고안 실행 현황 확인 - 주기적 회의 및 리포트	개선 실행력 확보
교육·코칭	- 담당자 대상 실무 교육 - 신규 절차 운영 지원	내부 역량 강화
재진단	- 일정 기간 후 동일 항목 재점검 - 개선 성과 측정	보안수준 지속 개선
지속 모니터링	- 로그/보안솔루션 연계 점검 - 이상징후 사전 탐지	사고 예방 및 대응력 확보

Follow-up Best Practice

- **단기 점검: 개선 권고 이행 점검(1~3개월 후)**
- **중기 점검: 운영 안정화 확인(6개월 후)**
- **장기 점검: 재진단 및 신규 리스크 분석(1년 주기)**
- **협력 체계: 고객 내부 보안팀과 공동 운영**

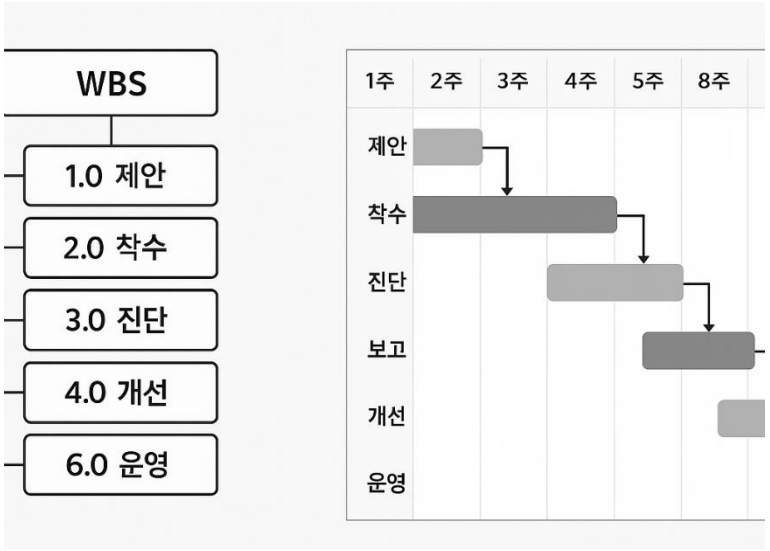


2. 컨설팅 프로세스 흐름_작성 사례 - 일정 관리 화면

WBS(Work Breakdown Structure): 프로젝트 작업을 세부 단계로 쪼개어 일정·자원·책임을 명확히 하는 도구, 보안 컨설팅 프로젝트에서는 제안 → 착수 → 진단 → 보고 → 개선 → 운영 단계별 작업을 WBS로 세분화

WBS 예시

WBS 코드	단계	세부 작업	기간	담당자
1.0	제안	RFP 검토, 제안서 작성	1주	컨설팅팀
2.0	착수	킥오프 미팅, 범위 정의	1주	PM + 고객
3.0	진단	관리적 점검, 기술적 점검, 인터뷰	3주	보안컨설턴트
4.0	보고	결과보고서 작성, 리뷰, 발표	1주	PM + 팀원
5.0	개선	개선안 제시, 실행 지원	2주	컨설턴트 + 고객
6.0	운영	Follow-up, 재진단	3~6개월	PM + 고객



2. 컨설팅 프로세스 흐름_품질 관리

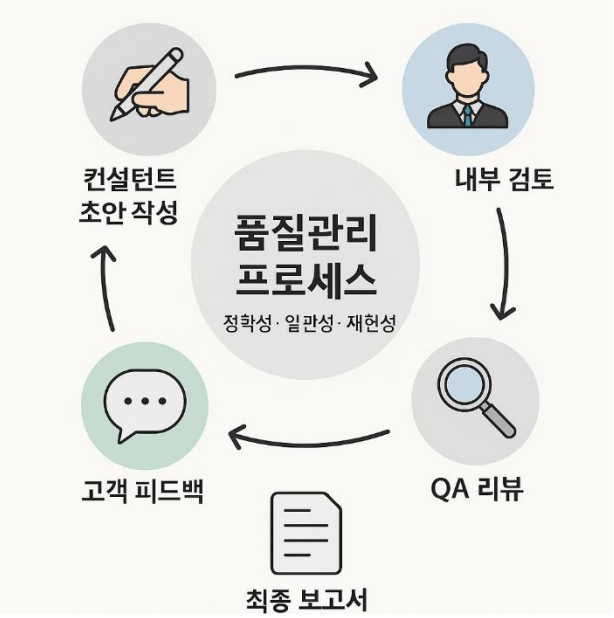
품질관리(QA)는 산출물(보고서, 개선안, 체크리스트 등)의 정확성·일관성·재현성을 확보하기 위한 과정, 컨설팅의 신뢰성을 좌우하는 핵심 요소

품질관리 주요 포인트

구분	관리 포인트	체크리스트
정확성	- 취약점 내용·증적의 사실 확인 - 기술 설명의 오류 여부	로그, 스크린샷, 인터뷰 기록과 일치 여부
일관성	- 보고서 형식/용어 표준화 - 결과 표현 방식 동일화	템플릿 준수 여부
재현성	- 동일 조건에서 동일 결과 도출 가능	점검 방법·도구 기록
완전성	- 범위 내 모든 항목 점검 완료	누락 항목 확인
가독성	- 고객이 이해하기 쉬운 언어 사용 - 차트/도식 활용	불필요 기술 용어 최소화
보안성	- 산출물 보안등급 지정 - 자료 반출/배포 통제	내부 승인 절차 준수

결과 검토 프로세스

- **컨설턴트 1차 작성 → (초안)**
- **내부 검토 (선임/PM) → 내용 검증 & 품질 점검**
- **QA 팀/동료 리뷰 → 오탈자, 형식, 일관성 확인**
- **고객 내부 리뷰 → 초안 공유 & 피드백**
- **최종 보고서 확정** → 승인 & 납품



목차

1. 정보보호컨설팅 개요
2. 컨설팅 프로세스 흐름
3. **컨설턴트 역량 & 윤리**
4. 협업과 성과관리
5. 정보보호컨설팅 분류 및 유형
6. 기술적 보안진단

Q&A

3. 컨설턴트 역량 & 윤리_필요 역량

보안컨설턴트는 단순 기술자가 아니라 문제 해결자 + 전달자 + 소통자 역할을 모두 수행해야 하며, 분석·문서화·커뮤니케이션 3대 역량이 균형을 이룰 때 컨설팅의 신뢰성과 효과성이 보장

필요 역량 정리

구분	핵심 메시지	상세 내용
분석 역량	"문제의 원인을 정확히 파악해야 해결이 가능하다"	- 로그·설정·네트워크 구조 등 데이터 기반 분석 - 자산·위협·취약점 연계한 리스크 평가 - 도구(취약점 스캐너, 모의해킹 툴) 활용 - 단순 진단이 아니라 **원인-해결 경로** 제시
문서화 역량	"좋은 보고서는 곧 컨설팅의 성패를 좌우한다"	- 결과보고서·개선안 문서화 능력 - 템플릿 준수, 증적 관리(스크린샷·로그 포함) - 고객이 이해할 수 있는 표현 사용 - 불필요한 기술 용어 대신 **가독성** 확보
커뮤니케이션 역량	"소통이 부족하면 좋은 분석도 무용지물"	- 고객 맞춤형 설명 능력 - 내부·외부 협업 및 갈등 조정 - 프레젠테이션·워크숍 진행 능력 - 고객이 **실제 개선을 실행하도록 설득**하는 힘

3. 컨설턴트 역량 & 윤리_분석 역량사례(리스크 분석 실무)

분석 역량은 자산·위협·취약점을 연결해 위험(Risk)을 도출하는 과정에서 가장 크게 발휘됨,
컨설턴트는 단순 진단 결과 나열이 아니라, 리스크 수준 평가와 개선 방향 제시까지 이끌어야 함.

리스크 분석 절차(실무 흐름)

1. 자산 식별
 - 중요 시스템, 네트워크 장비, 개인정보DB 등
 - 예: 고객사 금융 DB 서버
2. 위협 도출
 - 내부자 오남용, 해킹 시도, 랜섬웨어 등
 - 예: 외부 공격자가 DB 계정 탈취
3. 취약점 확인
 - 패치 미비, 취약한 인증, 보안설정 부재
 - 예: DB 접근통제 미흡
4. 리스크 평가
 - 가능성 × 영향도 → 위험 수준 산정
 - 예: “높음(High)” → 개인정보 대량 유출 위험
5. 개선 권고
 - 단기: 계정 접근제어 강화
 - 중기: DB 암호화 적용
 - 장기: DLP(Data Loss Prevention) 도입

사례 예시

단계	실제 예시
자산	금융 고객 DB 서버
위협	외부 해킹 시도 (SQL Injection)
취약점	웹 애플리케이션 입력값 검증 미흡
리스크	고객 개인정보 대량 유출 (High)
개선안	WAF(Web Application Firewall) 적용, 소스코드 검증 프로세스 강화



3. 컨설턴트 역량 & 윤리_커뮤니케이션 스킬(고객 미팅 기법)

보안컨설턴트는 단순한 기술 보고자가 아니라, 고객이 이해할 수 있도록 설명하고 설득하는 전문가, 고객 미팅은 신뢰 구축과 컨설팅 성공의 핵심 접점

고객 미팅 핵심 기법

단계	기법	설명
준비 단계	자료 사전 공유	고객이 사전에 내용을 파악할 수 있도록 간단한 브리핑 문서 제공
	질문 리스트 작성	예상 질문/이슈 정리 후 대응 시나리오 준비
진행 단계	고객 눈높이 맞춤 설명	기술 용어는 쉽게 풀어 설명, 비즈니스 영향 중심으로 전달
	경청 & 피드백	고객 의견 경청 후 정리·반복 확인 (Active Listening)
	시각자료 활용	PPT, 다이어그램, 사례 기반 설명으로 이해도 강화
마무리 단계	Action Item 정리	합의된 개선 과제/일정을 표로 정리 후 공유
	후속 Follow-up	미팅 요약본(회의록) 전달 → 신뢰 확보

고객 미팅 성공 포인트

- **신뢰: 약속한 시간·자료·Action Item 반드시 이행**
- **명확성: 복잡한 기술 설명 대신 "왜 중요한가?"에 집중**
- **참여 유도: 일방향 발표보다 질의응답·토론 중심**
- **기록 관리: 회의록/보고자료로 증적 확보**



3. 컨설턴트 역량 & 윤리_문서화 스킬(보고서 작성 요령)

좋은 보고서 = 구조화 + 명확성 + 신뢰성
컨설턴트의 전문성은 분석 뿐 아니라, 보고서를 통해 고객이 이해하고 실행할 수 있게 전달하는 능력에서 입증

보고서 작성 요령

구분	핵심 메시지	상세 내용
구조화	"보고서는 체계적인 구조가 기본"	- 표준 템플릿 활용 - 목차/챕터별 흐름 유지 - 핵심 요약 → 상세 설명 → 증적 순서
명확성	"고객이 이해할 수 있게 써라"	- 불필요한 기술 용어 지양 - 짧고 간결한 문장 사용 - 핵심 메시지를 굵게/도식으로 강조
신뢰성	"팩트와 증적이 담보되어야 한다"	- 증적(스크린샷, 로그) 포함 - 내용 일관성 유지 - 오탈자·표현 오류 최소화

3. 컨설턴트 역량 & 윤리_윤리의 중요성(보안 컨설턴트의 책임)

보안컨설턴트는 조직의 기밀 정보와 보안 현황을 직접 다루는 사람, 따라서 윤리적 책임과 신뢰 확보가 컨설팅 성과보다 먼저 전제되어야 한다. 기술적 역량만큼 윤리적 태도와 책임감이 중요

보안 컨설턴트의 윤리·책임

구분	주요 내용	설명
기밀 유지	고객 정보 보호	고객의 보안 수준·약점을 외부에 절대 유출하지 않음
객관성	공정한 진단	특정 제품·솔루션에 치우치지 않고 객관적 결과 제시
책임감	실행 가능한 개선안 제시	단순 지적이 아닌 고객이 실행할 수 있는 현실적 대안
전문성	지속적 학습·업데이트	최신 보안 트렌드, 법적 요구사항 반영
신뢰 구축	고객과의 장기 파트너십	단기성과보다 지속적 보안 수준 향상 지원



3. 컨설턴트 역량 & 윤리_윤리위반 사례

기밀 유출, 이해상충 & 객관성 위반, 책임 회피

1. 사례 ① 기밀 유출

- 상황: 컨설턴트가 고객사 진단 과정에서 확보한 시스템 취약점 자료를 개인 USB에 저장 → 외부 유출
- 결과: 고객사의 내부망 구조와 취약점 정보가 외부 공격자에게 악용됨
- 교훈: 기밀 유지 위반은 기업 보안사고의 직접 원인이 될 수 있음

2. 사례 ② 이해상충 & 객관성 위반

- 상황: 특정 솔루션 판매사와 협력 관계에 있던 컨설턴트가, 모든 고객사에 해당 솔루션만 권장
- 결과: 고객사는 불필요한 비용을 지출하고, 보안 수준은 실질적으로 개선되지 않음
- 교훈: 객관성 상실은 고객 신뢰를 무너뜨리고 장기 계약 기회를 잃게 함

3. 사례 ③ 책임 회피

- 상황: 컨설턴트가 위험 수준이 높은 취약점을 발견했으나, 고객이 부담을 느낄까봐 보고서에서 축소 기재
- 결과: 실제 사고 발생 (랜섬웨어 공격), 고객이 컨설팅 실패로 간주
- 교훈: 책임감 부족은 고객의 피해를 키우고, 컨설턴트 평판에 치명적 타격

3. 컨설턴트 역량 & 윤리_사전동의·비밀유지

컨설팅은 고객 기밀을 직접 다루므로, 법적·계약적 장치를 통해 보안성과 신뢰를 확보해야 한다. 사전 동의 & NDA는 프로젝트 수행의 기본 전제조건

필수 조항 정리

구분	필수 조항	설명
비밀유지 범위	고객 정보, 진단 결과, 내부 자료	모든 산출물과 증적은 NDA 대상 포함
정보 사용 목적	진단 및 컨설팅 목적 외 사용 금지	교육, 외부 발표 등에 활용 불가
정보 접근 권한	컨설턴트·팀 내 승인 인원 한정	불필요한 외부인·3자 접근 차단
보관 및 폐기	프로젝트 종료 후 자료 반납·파기	USB·이메일 등 사본 관리 금지
법적 책임	위반 시 손해배상, 계약 해지 가능	금전적·법적 책임 명시
사전 동의 절차	점검 범위, 인터뷰, 증적 수집 사전 합의	고객의 서면 동의 필수



3. 컨설턴트 역량 & 윤리_전문가 자세(솔루션이 아닌 신뢰 제공)

컨설턴트의 가치는 제품 제공이 아니라 신뢰 제공, 고객은 “무엇을 사야 하는가?”보다 “누구를 믿고 맡길 수 있는가?”를 우선시함. 전문가 자세 = 객관성 + 윤리성 + 실행 가능성

전문가 자세의 3대 원칙

구분	핵심 메시지	상세 내용
객관성	특정 솔루션 강매보다 **중립적 시각**	고객 상황에 맞는 다양한 대안 제시
윤리성	기밀 유지와 공정성 확보	고객 신뢰는 윤리 준수에서 시작
실행 가능성	실행되지 않는 권고는 무의미	현실적이고 적용 가능한 개선안 제시



3. 컨설턴트 역량 & 윤리_핵심 요약

보안컨설턴트의 성과는 기술 역량 + 윤리적 책임의 조화에서 나온다. 분석·문서화·커뮤니케이션 역량이 실무를 뒷받침하고, 기밀 유지·객관성·책임감은 신뢰를 구축

핵심 요약

영역	주요 포인트	요약 메시지
역량 (Skills)	분석 – 문제 원인 규명 문서화 – 명확한 보고서 커뮤니케이션 – 고객 협업·설득	**성과를 만드는 힘**
윤리 (Ethics)	기밀 유지 – 고객 정보 보호 객관성 – 공정한 진단 책임감 – 실행 가능한 개선안 제시	**신뢰를 만드는 힘**



목차

1. 정보보호컨설팅 개요
2. 컨설팅 프로세스 흐름
3. 컨설턴트 역량 & 윤리
4. **협업과 성과관리**
5. 정보보호컨설팅 분류 및 유형
6. 기술적 보안진단

Q&A

협업 실습

목차

1. 정보보호컨설팅 개요
2. 컨설팅 프로세스 흐름
3. 컨설턴트 역량 & 윤리
4. 협업과 성과관리
5. **정보보호컨설팅 분류 및 유형**
6. 기술적 보안진단

Q&A

5. 정보보호컨설팅 분류 및 유형_컨설팅 분류(관리·기술·물리)

정보보호컨설팅은 '기술·관리·물리' 3대 영역으로 구분되며, 각 영역별 특성에 맞는 진단·개선 활동을 통해 조직의 보안 체계를 종합적으로 강화함

정보보호컨설팅 범위

영역	주요 목적	세부 활동 예시	기대 효과
관리 영역 (Managerial)	조직 차원의 **보안 정책·프로세스 체계화**	- ISMS/ISMS-P 인증 컨설팅 - 개인정보보호 관리체계 수립 - 위험 분석 및 대응 프로세스 설계 - 보안 거버넌스 및 조직 역할 정의	- 법규·규제 준수 - 조직 차원의 책임·권한 명확화 - 보안 관리 성숙도 향상
기술 영역 (Technical)	IT 인프라 및 애플리케이션의 **취약점 식별·제거**	- 서버·네트워크 취약점 진단 - 웹/모바일 모의해킹 - 클라우드 보안 점검 - 악성코드 탐지 및 분석	- 해킹 및 내부 침해 위험 감소 - 최신 위협에 대한 기술적 대응력 확보
물리 영역 (Physical)	시설 및 자산에 대한 **물리적 접근 통제 및 보호**	- 출입통제 시스템 점검 (ID카드, 생체인증) - CCTV·감시장치 운영 - 서버실·전산실 보안 관리 - 재해복구센터(DR) 및 비상 대응 체계 검토	- 물리적 침입 방지 - 재해·재난 시 신속한 복구 가능 - 자산의 안정적 운영 보장

정보보호컨설팅은 기술적 취약점 뿐 아니라, 관리적 프로세스와 물리적 보안까지 통합적으로 다루는 종합적 활동이다.

5. 정보보호컨설팅 분류 및 유형_컨설팅 유형

조직의 정보자산을 안전하게 보호하기 위해 보안 취약점을 진단하고, 위험을 평가하여, 개선 방안을 설계하는 전문 서비스로 고객의 산업 특성, 보유 시스템, 법적 규제에 따라 맞춤형으로 구성됨

주요 유형별 세분화

구분	유형명	주요 내용 및 목적	적용 사례	관련 법·기준
관리체계 기반	ISMS/ISMS-P 컨설팅	조직 전반의 정보보호 및 개인정보보호 체계 수립	공공기관, 대기업, 병원	ISMS-P 인증 기준, 정보통신망법
기술 기반	서버/웹/DB 진단	시스템의 기술적 취약점 분석	IDC, 금융사, 중소기업	OWASP, CVE, ISMS 기술 항목
	웹 어플리케이션 진단	웹 기반 서비스에 대한 보안 점검	쇼핑몰, 포털, 교육플랫폼	OWASP Top 10
	모의해킹(PenTest)	실제 공격 시나리오 기반의 침투 테스트	금융, 전자상거래, 보안시스템	NIST SP800-115, ISMS
개인정보 기반	개인정보 보호 컨설팅	개인정보 수집·이용·파기 등 처리 활동 점검	병원, 교육기관, 플랫폼 기업	개인정보보호법, GDPR
	개인정보영향평가(PIA)	시스템 도입 시 개인정보 처리 위험 사전 평가	공공시스템, 대형 포털	개인정보보호법 제33조
클라우드 기반	CSAP 인증 컨설팅	공공기관 대상 클라우드 보안 인증 대응	클라우드 공급자, SaaS 사업자	행정안전부 고시
산업특화형	OT/ICS/IoT 보안 컨설팅	산업제어시스템 보호, 스마트팩토리 보안 강화	반도체, 에너지, 제조업	KISA OT 보안가이드, 기반보호법
전략·제도 기반	위험관리 및 평가 컨설팅	위험 분석, 대응전략 수립 및 문서화	전사 보안 정책 수립	ISO/IEC 27005, ISMS
	정보보호 중장기 전략 수립	조직 맞춤형 보안 거버넌스 설계	공공기관, 지주회사	산업법, 보안 아키텍처 가이드
	컴플라이언스 대응	GDPR, 전자금융감독규정, 국외 법규 대응	해외 진출 기업, 핀테크	GDPR, 금융감독규정
운영 기반	정보보호 교육 컨설팅	보안 인식 제고, 실무 교육 커리큘럼 설계	공공기관, 전사 대상	개인정보보호법, 자체 교육지침
	정보보호 감사 대응	내부감사, 외부 인증 심사 대비 컨설팅	인증 직전 기업	ISMS 심사기준, 내부통제기준

5. 정보보호컨설팅 분류 및 유형_관리체계 컨설팅(ISMS/ISMS-P 등)

ISMS/ISMS-P 인증 컨설팅은 조직의 정보보호 수준을 정량적으로 평가하고, 법령·기준에 따른 체계 구축 및 인증 획득을 지원하는 종합 서비스

관리체계 컨설팅(ISMS/ISMS-P) 개요

구분	ISMS	ISMS-P
정의	정보보호 관리체계 수립 및 운영 인증	정보보호 + 개인정보보호 통합 인증
대상	일정 규모 이상 공공기관·기업	개인정보를 처리하는 사업자
목적	조직의 정보보호 관리수준 인증	개인정보 보호체계까지 포괄 인증
근거	정보통신망법 제47조	개인정보보호법 제32조의2

인증기준 구성

- **ISMS: 관리체계 12개 항목 + 보호조치 60개 항목**
- **ISMS-P: ISMS 기준 + 개인정보 처리단계별 21개 항목 추가**

(총 101개 항목)

영역	예시항목
관리체계	정보보호 정책 수립, 최고책임자 지정, 위험분석 수행
보호조치	접근통제, 암호화, 로그관리, 출입통제, 악성코드 방지
개인정보보호	수집 제한, 이용·제공 통제, 보유기간 준수, 영향평가

컨설팅 주요 활동

1. 진단 및 Gap 분석

- 현재 운영 중인 정보보호 활동 분석

- 인증 기준과의 차이점 도출

2. 정책 및 절차 문서화

- 정보보호/개인정보보호 정책서, 지침, 운영 절차 문서 작성

3. 위험분석 및 보호조치 설계

- 자산 식별, 위협/취약점 분석, 위험도 평가 및 대응

4. 증적자료 수집 및 관리

- 이행증적(로그, 시스템 설정, 회의록 등) 확보 및 보관

5. 내부 점검 및 모의심사 훈련

- 인증 대응 리허설 및 질의응답 시뮬레이션

5. 정보보호컨설팅 분류 및 유형_기술진단 컨설팅(1/2)

기술진단 컨설팅은 조직 내 정보시스템 및 IT 인프라 전반에 존재하는 보안 취약점(Vulnerability)을 식별하고, 이를 기반으로 위험을 분석하며, 개선 및 대응방안을 제시하는 기술 중심의 보안 컨설팅

목적

- **목적:**
  - **외부 공격에 노출될 수 있는 시스템의 잠재적 위협 요소 식별**
  - **보안 사고 사전 예방 및 대응 전략 마련**
  - **ISMS/ISMS-P 등 인증의 기술 보호조치 항목 충족**

진단 대상 시스템 세부

진단 대상	상세 설명	예시
서버 / OS	리눅스, 윈도우, AIX 등 운영체제 환경	웹/DB 서버, 백업서버
네트워크장비	라우터, 스위치, 방화벽, 무선AP 등 네트워크 인프라	VPN 장비, NAC, WAF
DBMS	Oracle, MSSQL, MySQL, MariaDB 등	ERP DB, 고객 DB
Web/WAS	웹 애플리케이션, 관리자페이지, API 서버 등	포털, 쇼핑몰, 관리자콘솔
보안솔루션	IDS, IPS, EDR, UTM 등	보안관제 연계 장비

진단 방식

- **자동화 도구 기반 점검**
  - **스캐너 활용: Nessus, OpenVAS, Acunetix, Nikto 등**
  - **장점: 반복적 점검에 용이, 정량화된 위험도 제공**
  - **한계: 비즈니스 로직, 논리적 취약점 미 탐지 가능성**
- **수기 진단 (전문가 수동 점검)**
  - **수작업 탐색 및 시나리오 기반 점검 (예: 인증우회, 세션 탈취 등)**
  - **장점: 사고 재현, 업무 흐름 기반의 논리적 오류 발견 가능**
  - **보완: 도구 기반 점검의 한계 보완**

5. 정보보호컨설팅 분류 및 유형_기술진단 컨설팅(2/2)

적용 진단 기준

기준명	설명
OWASP Top 10	웹/앱 중심의 국제 표준 취약점 분류 (예: SQL, XSS, Broken Auth 등)
CVE/CWE	국제 공개 취약점 식별 번호 체계 및 분류 체계
CCE	보안설정항목
CVSS	취약점 심각도 등급 산정 체계 (Base / Temporal / Environmental Score)
ISMS / CSAP / NIST	국내외 인증 기준 및 점검 기준서(KISA, NIST SP800-115 등)

보고서 구성

구성 항목	내용
개요 및 범위	대상 시스템 목록, 점검기간, 점검 방식
주요 결과 요약	자산별 위험도, 취약점 수량 분표, 고위험 항목 요약
상세 진단 결과	각 취약점별 설명, 스크린샷, 재현 절차
위험도 등급	CVSS 기반 점수 산정 및 등급(낮음/보통/높음/매높음)
개선 권고안	기술적 조치 방안, 설정 가이드, 패치 정보 등
참고자료	진단 도구, 기준 문서, CVE 링크 등

진단 프로세스

1. 진단 및 Gap 분석

- 현재 운영 중인 정보보호 활동 분석

- 인증 기준과의 차이점 도출

2. 정책 및 절차 문서화

- 정보보호/개인정보보호 정책서, 지침, 운영 절차 문서 작성

3. 위험분석 및 보호조치 설계

- 자산 식별, 위협/취약점 분석, 위험도 평가 및 대응

4. 증적자료 수집 및 관리

- 이행증적(로그, 시스템 설정, 회의록 등) 확보 및 보관

5. 내부 점검 및 모의심사 훈련

- 인증 대응 리허설 및 질의응답 시뮬레이션

5. 정보보호컨설팅 분류 및 유형_개인정보보호 컨설팅(1/2)

개인정보보호법 및 관련 가이드라인에 따라, 조직이 개인정보를 수집·이용·보유·파기 등 전 과정에서 적법하고 안전하게 처리하고 있는지를 진단하고 개선을 지원하는 컨설팅 서비스

개인정보보호 컨설팅의 주요 유형

유형	설명	주요 대상 기관
일반 개인정보보호 진단 컨설팅	개인정보보호법 전반에 따른 조직의 현행 운영실태 점검	공공기관, 일반 기업
PIA 컨설팅(개인정보보호 영향평가)	신규 시스템 구축·변경 시 개인정보 침해 위험 사전 분석 및 대응 전략 수립	공공기관
수탁사 관리 컨설팅	위탁 계약 및 수탁사 통제체계의 적정성 점검	금융기관, 대기업 등
개인정보관리체계(ISMS-P 대응) 컨설팅	ISMS-P 인증을 위한 개인정보보호 항목 진단 및 문서화	인증추진기업, 병원, 금융 등
국외 법규 대응 컨설팅(GDPR, CBPR 등)	GDPR, CBPR 등 해외 진출 기업의 글로벌 개인정보보호 규정 대응	유럽 및 APEC 진출 업체

주요 점검 방법

방식	내용
문서점검	개인정보처리방침, 위탁 계약서, 내부관리계획, 동의서 양식 등 확인
시스템 설정 점검	개인정보 저장 위치, 접근통제, 로그관리, 암호화 설정 확인
인터뷰	개인정보취급자, 관리자 등 실무자 대상 업무처리 방식 확인
흐름도 분석	개인정보 수집→저장→이용→제공/파기 흐름도 시각화
PIA 프로세스 점검	시스템 변경 시 PIA 대상 여부, 평가 수행, 결과 보고 여부 등

5. 정보보호컨설팅 분류 및 유형_개인정보보호 컨설팅(2/2)

핵심 점검 항목(개인정보보호법 기준)

구분	주요 점검 항목
처리 단계	수집 항목 최소화, 동의서 명확성, 고지 의무 준수
이용 및 제공	목적 내 이용, 제3자 제공 시 사전 동의 및 기록 보존
보유 및 파기	보유기간 설정, 정기적 파기, 파기내역 기록 관리
정보주체 권리	열람·정정·삭제·처리정지 요청 접수 및 대응 절차
위탁관리	수탁자 명시, 계약서 포함항목 준수, 수탁자 실태점검
안전성 확보조치	접근통제, 암호화, 로그보관, 백신/보안패치 적용, 모니터링 체계
PIA(해당 시)	처리 단계 분석, 고위험 식별, 보호조치 대안 제시 및 보고서 작성

법적 및 인증 기준

기준	내용
개인정보보호법 제33조	개인정보 영향평가(PIA) 의무화
시행령 제35조	PIA 대상 및 수행 방법 규정
개인정보보호위원회 고시	보호조치 기준, 위탁관리, 영향평가 보고서 양식 등
ISMS-P 인증 기준	개인정보 처리 단계별 21개 점검 항목 포함

기대효과

- **개인정보 처리의 법적 리스크 사전 제거**
- **과징금 및 행정제재 예방(위반 시 최대 5천만원 이하)**
- **정보주체 신뢰도 향상 → 기업 이미지 강화**
- **ISMS-P 인증 획득 및 내부감사 대응력 강화**
- **글로벌 대응 기반 확보 (GDPR 등 외부 감사 수검 시 유리**

5. 정보보호컨설팅 분류 및 유형_융합보안 컨설팅(1/2)

융합보안 컨설팅은 정보기술(IT)과 운영기술(OT), IoT 디바이스, 클라우드 환경이 융합된 디지털 인프라에서 발생하는 복합 보안 위협에 대한 대응 체계 수립을 지원하는 전문 보안 컨설팅

주요 영역 및 컨설팅 내용

영역	주요 대상 자산	진단방법	컨설팅 주요 활동
OT(운영기술)	SCADA, DCS, PLC, HMI 등 산업제어시스템	네트워크 흐름 분석, 포트/서비스 점검, 접근제어 검토	- 제어망/업무망 분리 여부 분석 - 원격접속 통제 - 인증 및 계정 설정 상태 점검 - NIST SP800-82 기반 위험도 평가
IoT(사물인터넷)	CCTV, 센서, 의료기기, 스마트미터 등	디바이스 설정 분석, 펌웨어 분석, 네트워크 캡처	- 기본 비밀번호 존재 여부 - OTA 보안 여부 - 통신 암호화(TLS 등) - 하드코딩된 인증정보 탐지
클라우드 보안	AWS, Azure, GCP, Naver Cloud 등	콘솔 설정 확인, 로그 감사, IAM 분석	- CSAP 인증 기준 점검 - IAM 권한 최소화 설정 - S3/Bucket 공개 설정 여부 - 백업 및 DR 체계 점검 - ISO/IEC 27017, NIST SP800-144 기반 자문

기술적 진단 도구 예시

환경	주요 진단 도구	기능
OT	Wireshark, GRASSMARLIN	제어 프로토콜 분석, ICS 네트워크 매핑
IoT	Binwalk, Firmwalker	펌웨어 정적 분석, 인증정보 추출
클라우드	ScoutSuite, Prowler	AWS/GCP 설정 취약점 스캐닝

5. 정보보호컨설팅 분류 및 유형_융합보안 컨설팅(2/2)

적용 표준 및 제도 근거

기준명	설명	적용 대상
NIST SP800-82	산업제어시스템(ICS) 보안 가이드라인	공장, 정유시설, 발전소 등
IEC 62443	제어시스템 국제 보안 표준	OT 전체 환경
CSAP	클라우드 보안인증제도 (행안부 고시)	공공 클라우드 서비스
ISO/IEC 27017	클라우드 정보보호 가이드라인	퍼블릭/프라이빗 클라우드
KISA IoT 보안인증기준	IoT 기기 설계 및 운영 보안 기준	제조사, 공공 IoT 플랫폼 등

적용 사례

기업/기관	수행내용	효과
제조사 A	스마트공장 제어망 구성점검, IEC 기준 맞춤 설계	제어계층 접근제어 강화 및 위험도 '매우 높음' → '보통' 감소
지자체 B	스마트시티 IoT 통합 플랫폼 점검	수집센서의 인증·암호화 적용 및 OTA 안전화
SaaS 기업 C	퍼블릭 클라우드 기반 CSAP 대응 컨설팅	IAM, S3 정책 개선 → CSAP 인증 통과

5. 정보보호컨설팅 분류 및 유형_전자금융기반시설 보안 컨설팅

전자금융기반시설 컨설팅은「전자금융거래법」제21조의3에 따라,금융 IT 시스템의 보안성과 안정성 확보를 위해 요구되는 취약점 점검 및 기술적 보호조치 이행 여부를 진단하는 전문 서비스

적용 대상

구분	대상시스템 예시	비고
고위험 전자금융서비스	인터넷·모바일 뱅킹, 전자지급결제(PG), 간편송금, 암호화폐 지갑 등	건당 100만 원 이상, 인증요구 트랜잭션 포함
전자금융업자	PG사, 간편결제사, 송금앱, 마이데이터 플랫폼	전자지급결제대행사(PG)는 반드시 연 1회 이상 수행
핀테크 기업	API 중계 플랫폼, 오픈뱅킹 연계 시스템	금융기관 연동 시 기반시설로 간주됨

주요 점검 항목(전자금융감독규정 기준 세분화

점검영역	주요 점검 항목	점검 세부 내용
시스템 보호조치	접근통제, 백신관리, 로그관리, 암호화 적용	방화벽 설정, 관리자 인증, 접근이력 남기기 등
이상거래 탐지	FDS 운영 여부	고위험 거래 탐지 기준(패턴, 시간대, IP 등) 적용
이중 인증	OTP, 인증서, 지문, 앱 인증 등	건당 일정 금액 이상 거래 시 추가 인증 제공 여부
개발보안	소스코드 취약점 여부	SQL Injection, XSS 등 OWASP 기반 취약점 제거 여부
계정 및 권한 관리	관리자 권한 최소화	계정 권한 분리 여부, 업무시간 외 로그인 차단 여부
데이터 보호	저장·전송 데이터 암호화	고객정보·거래정보 암호화(대칭/비대칭), TLS 적용 여부
취약점 점검 이력	연 1회 이상 외부 점검 여부	보고서, 조치이력, 재점검 결과 등 보유 필요
보안 이벤트 대응체계	사고 발생 시 통보·보고절차	대응 시나리오, 로그 확보, 내부 보고 체계 등

5. 정보보호컨설팅 분류 및 유형_주요정보통신기반시설 보안 컨설팅

「정보통신기반보호법」에 따라, 국가·사회 기능을 수행하는 핵심 정보통신망이 사이버 위협에 의해 중단되지 않도록, 보호대책 수립 및 취약점 평가를 수행하는 전문 보안 진단

수행 대상

구분	설명	예시 기관
법적 지정 기반시설	정부가 지정한 14개 분야 주요기반시설	국방, 통신, 금융, 전력, 교통, 방송, 보건 등
중요정보통신망 운영기관	주요 공공시스템 및 국가 기반망 운영자	행정기관, 원자력, 대형 병원, 교통통제센터 등
지자체 기반시설	시·도 자체 운영 주요시스템	재난안전센터, 교통관제망, 상수도 SCADA 등

주요 점검 항목(KISA 기반보호 평가항목)

점검영역	주요 점검 항목	점검 세부 내용
접근통제	관리자 계정 분리, 망간 접근제어	제어망-업무망 간 방화벽 설정, 원격접속 제한
시스템 보안	OS 패치, 불필요 서비스 제거	점검도구(Nessus 등) 활용해 미비점 도출
암호화/인증	운영계정 암호 정책, 통신구간 암호화	SSH, HTTPS 적용, 2FA 구현 여부 등
백업 및 복구	이중화 구성, 정기 백업	백업 자동화, 재해복구 체계 확인
물리적 보안	출입통제, CCTV, 보안구역 설정	서버실 이중 출입통제, 영상 저장 주기 등
로그 및 감사	로그 생성·보관, 이상행위 감시	중앙집중 수집 여부, 보관 기간 확인
사고대응	침해사고 대응 시나리오, F/W 규칙 관리	사고보고 체계, 유관기관 공유 여부 포함

목차

1. 정보보호컨설팅 개요
2. 컨설팅 프로세스 흐름
3. 컨설턴트 역량 & 윤리
4. 협업과 성과관리
5. 정보보호컨설팅 분류 및 유형
6. **기술적 보안진단**

Q&A

6. 기술적 보안진단_기술진단의 목적

기술진단은 시스템의 안정성과 가용성을 확보하고 침해사고를 예방하기 위해 수행된다. 또한 ISMS 등 인증 및 법적 요구사항을 충족하여 조직의 신뢰성과 보안 수준을 강화하는 데 목적

기술 진단 목적

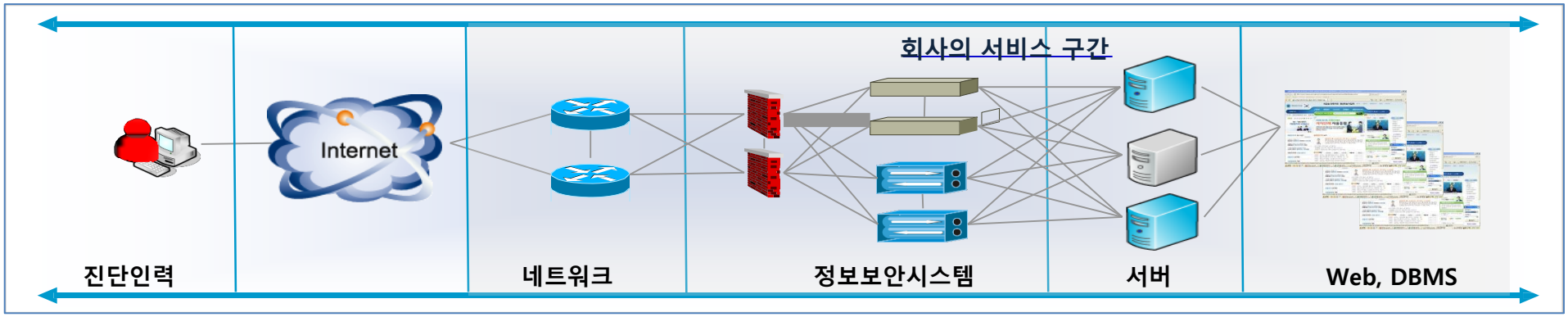
구분	목적	세부 설명	기대 효과
안정성 확보	시스템과 서비스가 안정적으로 운영되도록 보장	네트워크·서버·보안장비의 설정 점검, 장애 요인 사전 제거	서비스 중단 최소화, 운영 효율성 향상
가용성 확보	기반 서비스가 언제나 접근 가능하도록 보장	이중화·백업 정책 확인, 장애 대응 체계 점검	24/7 서비스 제공, 국민 불편 최소화
침해사고 예방	보안 위협에 대한 사전 차단 및 대응 능력 강화	취약점 스캐닝, 계정·권한 관리 점검, 모의침투 수행	해킹·랜섬웨어 등 사고 발생 가능성 감소
인증 대응	ISMS·ISMS-P, ISO27001 등 인증 요구 충족	관리적·기술적 보호조치 이행 수준 검증	인증 획득·유지 용이, 기업 신뢰성 제고
법적 요구사항 충족	정보통신기반 보호법 등 관련 법률 준수	규제기관의 정기점검·감독 대비	법적 리스크 감소, 제재 예방
조직 신뢰성 확보	이해관계자(정부·고객·파트너) 신뢰 확보	결과 보고서를 통한 투명한 보안 관리 증명	기업 평판 강화, 사업 경쟁력 향상

6. 기술적 보안진단_기술진단의 범위

기술진단은 주요 시스템(네트워크·서버·보안장비·애플리케이션 등)을 대상으로, 접근통제·암호화·로그 관리·취약점 점검 등 보안 필수 영역을 포괄적으로 점검

기술 진단 범위

구분	대상 시스템	주요 진단 항목	점검 목적
네트워크	방화벽, 라우터, 스위치 등	접근통제(ACL), 포트 관리, 망 분리 정책	불필요한 연결 차단, 외부 침입 방지
서버	OS, DB, 웹·메일 서버 등	계정·권한 관리, 보안패치, 암호화	서버 안정성 확보, 권한 오남용 차단
보안장비	IDS/IPS, EDR, DLP, VPN 등	탐지정책 설정, 로그·모니터링	위협 탐지 강화, 사고 발생 시 추적 용이
애플리케이션	주요 업무 시스템, 웹서비스	입력값 검증, 세션 관리, 취약점 점검 (OWASP Top 10)	데이터 보호, 웹 취약점 제거



6. 기술적 보안진단_기술진단 절차

주요정보통신기반시설 또는 전자금융기반시설 등에 따라 분석 기준이 수립되고, 진단솔루션 보유여부에 따라 취약점 진단 방법이 결정됨

기술 진단 절차

진단 대상선정 및 일정수립

- 대상 장비 및 범위 파악
- 진단 방법 선정(진단솔루션, 스크립트, 인터뷰 등)
- 시스템을 구분하여 계획수립
- 서버, 네트워크 장비, 보안장비 등 장비 유형별로 동일 모델 제품인 경우 샘플 점검 등과 같이 적용 범위는 협의 및 조정

취약점 진단

- 진단대상 정보자산을 분류하여 수동진단 또는 자동진단 수행
- 서버, 네트워크 및 보안장비에 대한 취약점 점검

취약점 자동 점검스크립트



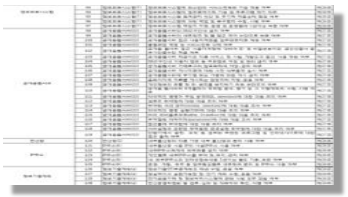
수작업 검증 (필요 시)



진단결과 분석

- 진단항목에 따른 결과 분석 및 보고서 작성
- 진단결과 협의 및 조치계획 수립

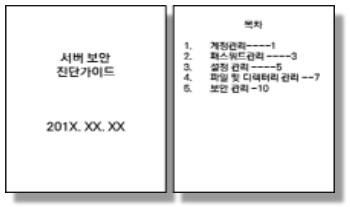
주요정보통신기반시설, 전자금융기반시설 취약점, 자체 취약점 기준 등 진단 항목 활용(체크리스트)



개선방안 수립

- 취약점에 따른 개선안 제시
- 대응방안 제시

취약점 조치 보안가이드



취약점 진단 후 개선필요사항 이행

- 조치계획에 따른 취약점 개선조치 확인 및 취약점 조치지원
- 이행의 범위는 협의·조정하여 수행

6. 기술적 보안진단_서버 진단

서버 진단은 계정·권한, 패치, 서비스 설정, 로그 관리 등을 점검하여 서버의 안정성과 보안성을 확보

서버 진단

[점검/조치결과 이력관리]

현황파악	진단 항목 및 스크립트 현행화	취약점 진단	분석·평가	개선방안 수립 및 이행
▪ 서버자산 ▪ 구성현황 파악	▪ 취약점 점검항목 검토 ▪ 취약점 점검항목 설정	▪ 진단 스크립트 배포 및 수동진단 수행 ▪ 오류발생 또는 필요시 수동진단 수행 및 인터뷰	▪ 유효성 검증 ▪ 현재 취약점 수준평가 ▪ 대책적용 계획 수립	▪ 취약점에 따른 개선안 수립 ▪ 개선안 이행가이드 ▪ 개선안 이행 점검

점검 항목(기반시설기준)

대상	점검 항목
Unix (AIX, HP-UX, Solaris, Linux)	계정관리
	파일 및 디렉터리 관리
	서비스 관리
	패치 관리
	로그 관리

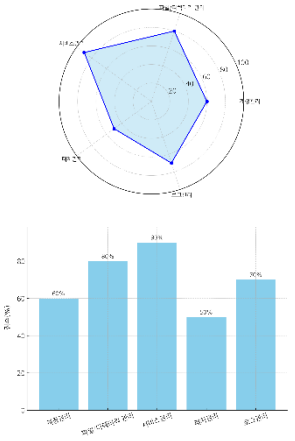
기반: 72, 금취: 77

대상	점검 항목
Windows (2003, 2008, 2012,2016)	계정 관리
	서비스 관리
	패치 관리
	로그 관리
	보안 관리
	DB 관리

기반: 82, 금취: 83

점검 결과

구분	점검 항목	서버1	서버2
계정 관리	Root 원격접속 제한	양호	양호
	계정 잠금 임계값	양호	취약
파일 관리	파일 및 디렉터리 소유자	취약	양호
	접속 IP 및 포트 제한	취약	양호
로그 관리	로그 정기적 검토	취약	양호
	시스템 로깅 설정	양호	취약



6. 기술적 보안진단_IT Infra 취약점 조치

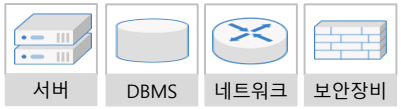
가이드라인 를 통해 향후 발생될 취약점을 사전에 방지할 수 있도록 하며, 식별된 취약점이 완전히 조치될 수 있도록 이행점검을 수행

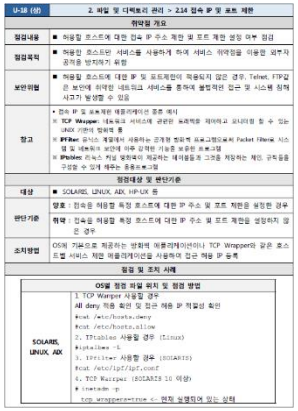
IT Infra 취약점 조치

진단 가이드라인 제공

- 점검/조치 방법 및 조치 영향이 반영된 최신 가이드라인 제공

진단가이드





조치 계획 수립

- 발견된 취약점에 대해 서비스 중요도에 따라 상/중/하 분류
- 운영현황을 고려한 즉시/단기/중기/장기 계획 수립

담당자 교육

- 진단 가이드 설명
- 점검기준, 조치 방법 교육

중요도 분류

- 중요도에 따라 상/중/하 분류

대책 분류

- 적용 난이도 및 위험도에 따라 긴급/단기/중기/장기 분류

조치 지원 및 이행 점검

- 점검/조치 방법 및 조치 영향이 반영된 최신 가이드라인 제공

주요 취약점 조치 지원

- 담당자 인터뷰
- 보안 가이드 라인 교육
- 도출 취약점에 대한 이해
- 즉시 조치 방안 지원

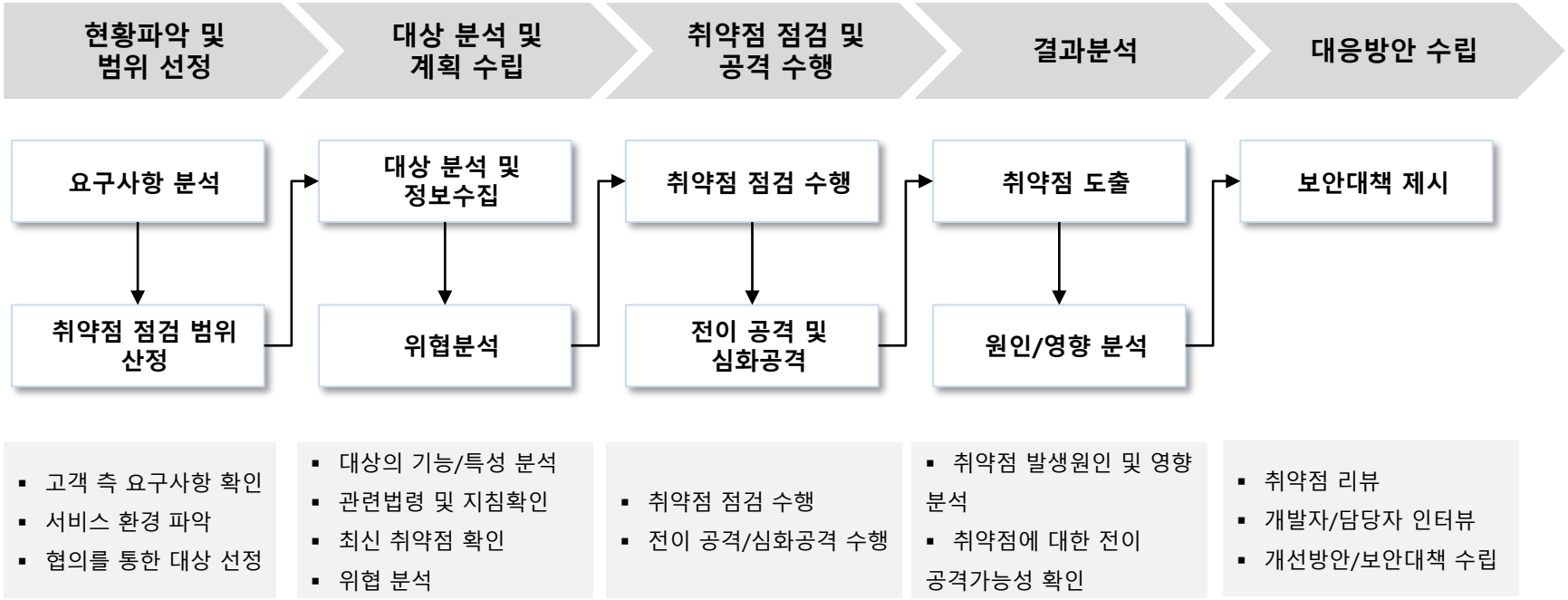
담당자 교육

- 조치 여부 점검
- 조치 결과 이력관리
- 미 조치 시 조치 원인 분석 및 조치사항 이행력 제고방안 마련

6. 기술적 보안진단_웹 애플리케이션 취약점 점검 절차

웹 애플리케이션 진단은 입력값 검증, 인증/세션 관리, 권한 통제, 오류 처리 등의 보안 결함을 점검

웹 애플리케이션 진단



6. 기술진단 실무_웹 취약점 진단 항목

웹 취약점 진단은 OWASP Top 10 항목을 기준으로 SQL, XSS, CSRF, 인증 우회 등 시스템을 직접 위협할 수 있는 요소들을 선별하여 자동/수기 병행 진단하며,위험도와 영향도에 따라 보안 조치의 우선순위를 설정

웹 취약점 진단 항목 예시 (OWASP Top 10 기반)

진단 항목	설명	위험도	영향도 예시
1. SQL Injection	웹 입력값을 통해 SQL 쿼리를 조작하여 데이터베이스에 비정상 접근	높음	사용자 인증 우회, 개인정보 탈취, DB 삭제 가능성
2. Cross-Site Scripting (XSS)	악성 스크립트를 삽입해 클라이언트에서 실행	중간~높음	세션 탈취, 피싱 페이지 유도, 사용자 행위 조작
3. Cross-Site Request Forgery (CSRF)	사용자의 인증 정보를 도용해 의도치 않은 요청 전송	중간	사용자 권한 하에 무단 데이터 변경, 결제 요청 등
4. 인증 우회 (Broken Authentication)	인증 과정의 논리적 결함을 통해 권한 없는 사용자 접근 가능	높음	관리자 권한 획득, 내부 시스템 접근
5. 관리자 페이지 노출	로그인 없이 관리자 페이지에 접근 가능하거나 경로가 외부에 노출	중간	관리자 계정 탈취 시 전체 시스템 제어 가능
6. 민감 정보 평문 전송	비밀번호, 주민번호 등의 정보가 암호화 없이 전송	높음	네트워크 스니핑을 통한 정보 탈취
7. 디렉토리 리스팅/파일 노출	웹 서버 내 디렉토리나 내부 파일이 외부에 노출	중간	코드 노출, 내부 경로 정보 수집에 악용
8. 보안헤더 미적용	X-Frame-Options, Content-Security-Policy 등의 보안 설정 미비	낮음~중간	클릭재킹, 콘텐츠 변조 가능성 증가
9. 입력값 검증 미비	클라이언트 입력값을 검증하지 않고 처리	중간	다양한 인젝션 공격, 에러 노출 가능
10. 세션 쿠키 보안 설정 미비	쿠키에 Secure, HttpOnly, SameSite 설정 누락	중간	세션 탈취, 중간자 공격(Man-in-the-Middle) 노출

6. 기술적 보안진단_진단보고서

기술진단 보고서는 개요 → 대상시스템 → 결과요약 → 상세결과 → 개선 권고 → 부록의 구조로 구성되며, 각 항목은 취약점의 영향도와 우선순위에 따라 정리하며, 스크린샷·로그 등 증적자료 포함은 인증 대응의 핵심

기술진단 보고서 작성 구성표(실무 중심)

항목명	목적	주요 포함 내용	형식/구성 요소	작성 시 팁
개요(Overview)	보고서 전체 목적과 개괄 설명	- 진단 목적 및 배경 - 진단 범위 및 일정 - 수행 인력 및 도구	서론 형식 서술 (1~2페이지)	인증·제안서 내용과 동일하게 작성
대상 시스템 (Target Scope)	점검 범위를 명확히 함	- 시스템/서버/웹 목록 - IP, OS, 담당자 - 네트워크 구성도(선택)	표 + 구성도 이미지	자산관리 목록 기반 작성
결과 요약 (Summary)	전체 취약점 현황을 한눈에 제시	- 총 발견 수 - 위험도별 분포 (고/중/저) - 시스템별 분포	통계표, 원형 차트, 바 차트 등	색상코드(RAG: 빨/주/녹) 적용
상세 결과 (Detailed Findings)	개별 취약점 설명과 조치 제안	- 취약점명, 위치(URL/파일명) - 개요, CVSS, 영향도 - 증적(스크린샷), 로그 - 조치방안(설정/패치/정책 등)	반복 템플릿 사용 표 형식 항목별 구분 박스	페이지 반복 시 일관성 유지 스크린샷 필수
개선 권고사항 (Recommendation)	대응 우선순위와 전략 제공	- 취약점별 조치 우선순위 - 단기/중기/장기 대응 계획 - 기술적/관리적 구분	항목 리스트 + 대응 전략표	조직 상황 반영 (운영 가능성 고려)
부록 (Appendix)	참고자료 및 원본 증적 제공	- 도구별 진단 리포트 원본 - 인터뷰 메모 - 기술 기준(CVE, OWASP 참조 등)	별첨 또는 첨부파일 형태	분리된 ZIP/링크로 제공도 가능
요약본 (PPT/한눈에 보기)	경영진 대상 결과 요약	- 핵심 위험 요약 - 심각 취약점 Top 3 - 대응 일정/예산 영향도	1~2장 PPT + 말풍선/아이콘 구성	비기술 대상용 표현 사용 권장

6. 기술적 보안진단_관리-기술연계

관리 영역(정책·지침·조직·교육)과 기술 영역(시스템·네트워크·애플리케이션 진단)은 별개가 아니라 상호보완적, 관리 항목에서 요구하는 기준이 기술 진단에서 검증 가능한 체크 포인트로 이어져야 함, 컨설팅에서는 관리·기술 진단 결과를 통합 리포트로 연결해야 고객이 실행할 수 있음

관리-기술 연계 매핑표(예시)

관리 영역 항목	대응되는 기술 진단 항목	설명
계정 관리 정책	서버 계정 점검 / 불필요 계정 확인	계정 생성·삭제 프로세스 ↔ 실제 계정 현황 비교
암호 정책	비밀번호 복잡성/만료 설정 점검	정책상 요구사항 ↔ 시스템 설정 일치 여부 검증
패치 관리 지침	서버/네트워크 보안 패치 점검	패치 주기 문서화 ↔ 실제 적용 여부 확인
접근 통제 정책	방화벽 ACL·포트 관리	네트워크 접근제어 문서 ↔ 실제 방화벽 룰 검증
로그 관리 지침	로그 수집·보관·모니터링 확인	관리적 요구사항 ↔ 기술적 로그 설정 점검
교육·인식 관리	피싱 메일 모의훈련 결과	교육 정책 ↔ 실제 훈련 결과 측정

6. 기술적 보안진단_테스트 시 주의(승인·기록 필요)

보안 진단은 반드시 승인(Authorization)을 받아야 합법적임, 모든 진단 활동은 기록(Log/Report)을 남겨야 책임 추적성 확보 가능, 승인·기록 절차 누락 시 법적 분쟁·신뢰 하락 발생

상세 내용

구분	체크포인트	설명
승인	공식 문서 승인	고객의 서면/전자 승인 필수
범위	점검 범위 명확화	서버, 네트워크, 웹, 클라우드 대상 확정
기록	활동 로그	점검 시도, 계정 접근, 테스트 결과 기록
증적	증거 확보	스크린샷, 로그파일, 보고서 초안 보관
리스크	승인·기록 누락 시 문제	무단 점검으로 간주, 법적 책임 발생

6. 기술적 보안진단_진단 기법 분류

기술진단 컨설팅은 IT 인프라의 보안 취약점을 식별하고 대응하는 활동으로, 자동화, 수기(수동) 진단, 혼합 방식이 있으며 속도, 정확도, 적용 범위에 따라 선택되어 효율성과 신뢰성을 모두 확보하는 혼합 방식이 가장 널리 활용

기술진단 기법 분류표

구분	자동화 도구 기반 진단	수기(수동) 진단	혼합(병행) 방식
정의	보안 스캐너로 시스템을 자동 탐지하고 보고서 출력	전문가가 설정, 로그 등 직접 점검 및 분석	자동 진단 결과를 기반으로 수기로 보완 분석
장점	- 빠른 수행 - 다수 자산 대응 - 취약점 DB 기반	- 정밀 분석 - 오탐 제거 - 설정/환경 고려 가능	- 효율 + 정확성 - 보고서 신뢰도 향상 - 인증 대응 최적
단점	- 오탐/미탐 존재 - 구조적 취약점 파악 어려움	- 시간 소요 많음 - 전문가 의존도 높음	- 관리 복잡도 ↑ - 비용 다소 증가 가능
필요 역량	도구 사용 역량 (GUI/CLI)	보안 설정 및 위협 분석 경험	도구 + 실무 보안 분석력
적용 대상	대규모 서버군, 정기점검, 초안 스크리닝	핵심 서버, 인증 서버, 민감 시스템	인증대응, 클라우드 보안, 보안사고 후 정밀진단
대표 도구	Nessus, OpenVAS, Acunetix, ScoutSuite	SSH, 콘솔 점검, 설정파일 비교, 공격 재현	자동도구 + 설정 로그 검토, 관리자 인터뷰 병행
ISMS 인증 적합성	일부 증적 활용 가능 (제한적)	증적 수집 및 인터뷰 대응 강점	필수적 (자동+수기 증적 병행 가능)

Q&A